

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR) Course 3: GRC103 - Risk Assessment and Management Techniques

GRC103 Lab: Practical Risk Monitoring with Wazuh

Student Name: Najma Abdi Omar

Reg. No: 2025/GRC/10331

Date: 18/10/2025

Module: Practical Risk Assessment Workshop

Executive Summary:

This lab was focused towards applying core Governance, Risk and Compliance (GRC) principles by working through a practical scenario in a guided session involving security monitoring with Wazuh, The Risk Monitoring Platform, aggregates and analyzes data for reporting, it functions as more than a SIEM with added tools for endpoint detection, compliance tools and monitoring features all in one. The objective of the lab was to demonstrate the Wazuh functionalities and address the risks of unauthorized file changes by deploying a file integrity monitoring tool (FIM) which is a **detective** tool, and observing how this control helps in detecting and responding to potential threats. We also saw other aspects of monitoring and compliance by exploring the Wazuh dashboard via the Kali Linux browser, it included compliance to standards and frameworks like HIPAA and PCI-DSS.

The lab started with a walkthrough session and followed up with individual setting up of the Wazuh Manager on Ubuntu and accessing the dashboard via Kali Linux, which served as the central point of monitoring. We also installed a Wazuh Agent on the host machine, windows in this case, followed by registration with the manager to allow real-time data collection. Once the systems were connected, we reviewed real-time log on changes made affecting the file integrity. During the set-up of the lab, we faced challenges with network, system crashing, unreachable Wazuh dashboard and this gave a hands-on

experience in tackling real world issues and troubleshooting to finally meet the objectives of the lab. In summary, we were able to:

- a. Operationalize a risk treatment by deploying a detective control
- b. Install The Wazuh Manager, Ubuntu (VirtualBox) whose role was the Risk Monitoring Platform which aggregates and analyzes data for reporting.
- c. Install The Wazuh Agent on Host machine (Windows) whose role was the Control Agent, installed on the asset (endpoint) being monitored.
- d. Connect the Technical Exercise to GRC Principles.

Below, we go through the steps and also provide the connection between the technical session and the GRC Principles.

Part One: Technical Session

1. Set up the Wazuh Manager and Establish the Manager and Host Machine's IP Address:

In this session, we downloaded the OVA file and imported it to our VirtualBox environment, set up network connections to allow communication between our host machine, Wazuh Server and Kali Linux where we will be accessing our Wazuh Dashboard from, we also established the IP Address of both the Wazuh Manager and Host Machine, to enable effective connection establishment to enable communication from Kali Linux to Wazuh Manager and also enable installation of monitoring agent.

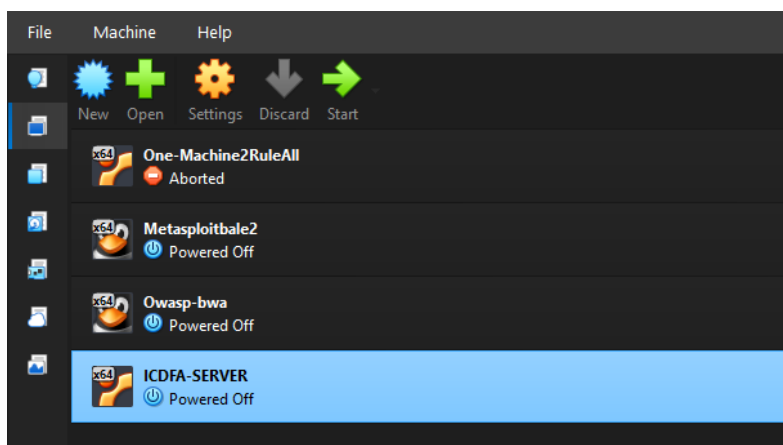


Figure1: Importing Wazuh Manager(ICDFA-Server)

```
inet 192.168.1.117 netmask 255.255.255.0 broadcast 192.168.1.255
inet6 fe80::a00:27ff:fe4c:44c4 prefixlen 64 scopeid 0x20<link>
ether 08:00:27:4c:44:c4 txqueuelen 1000 (Ethernet)
RX packets 125 bytes 12813 (12.8 KB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 46 bytes 4056 (4.0 KB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 2: Established the Wazuh Manager IP Address: 192.168.1.117, essential for accessing the manager dashboard from the Kali Linux Interface and setting up agent manager.

```
Wireless LAN adapter Wi-Fi 3:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::7f9:1406:2930:d3ec%5
    IPv4 Address. . . . . : 192.168.1.107
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1
```

Figure 3: Identified the Windows host machine IP Address, 192.168.1.107, necessary for installing and connecting the monitoring agent.

2. Accessing the Wazuh Dashboard

We accessed the Wazuh Dashboard from the established IP Address above, 192.168.1.117, via a browser. We initially first check through the terminal to confirm and establish connection, and confirm that the Wazuh server is active and proceeded to the browser to Interface with the dashboard.

Challenges here: security blocks, we accepted and continued, and a message that the Wazuh dashboard was not ready, we proceeded by troubleshooting and trying different technical solutions before finally proceeding and getting the challenge with API, once we repaired the same, we were able to open the dashboard as below, **NOTE:** there was no active agent at this point.

```
root@icdfa-server: ~  
File Actions Edit View Help  
(icdfa@icdfa)-[~]  
$ ssh root@192.168.1.117  
root@192.168.1.117's password:  
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage
```

Figure 4: Established and logged into the Wazuh Manager.

```
File Actions Edit View Help  
root@icdfa-server:~# sudo systemctl status wazuh-manager  
● wazuh-manager.service - Wazuh manager  
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)  
   Active: active (running) since Fri 2025-10-17 17:09:26 UTC; 2min 40s ago  
     Process: 720 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
```

Figure 5: Confirmed Wazuh Manager is Active.

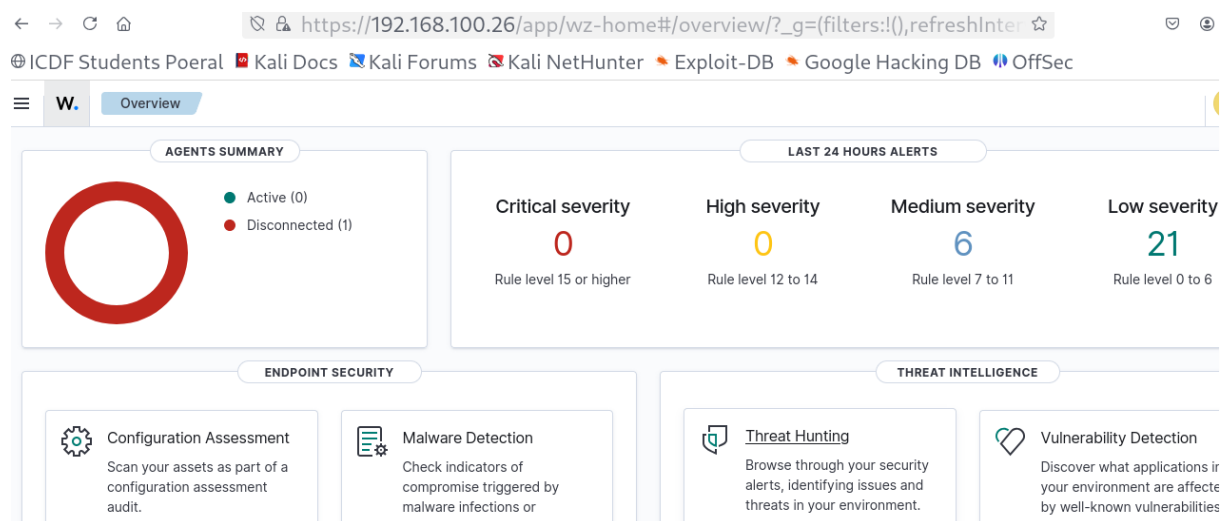


Figure 6: Browser-Based Access to the Wazuh Dashboard from Kali Linux Environment, No Active Agent.

3. Installing the Wazuh Agent (Windows)

After downloading the provided Wazuh Agent MSI Installer, we run the file and installed it on our host machine (Windows).

We then proceeded to register the agent-manager by running the below command which provided several option on what we needed to do with agents.

bash

sudo /var/ossec/bin/manage_agents

we then extracted the agent Key and copied the generated key to apply it on the Windows agent as below, **challenge here** is if the manage IP is captured incorrectly it does not reflect on the Wazuh Manager Dashboard. Here we registered **several agents** to see how it will reflect on the dashboard. We then proceed to confirm the agent is reflecting on the dashboard and proceed to navigate the dashboard and explore the different compliance, monitoring and reporting options.

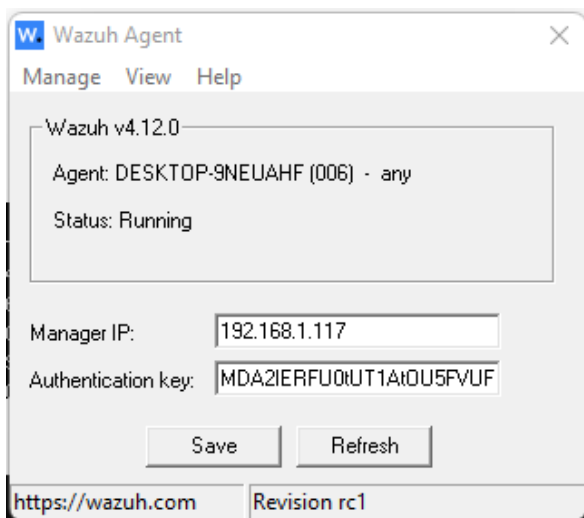


Figure 7: Agent successfully added and started.

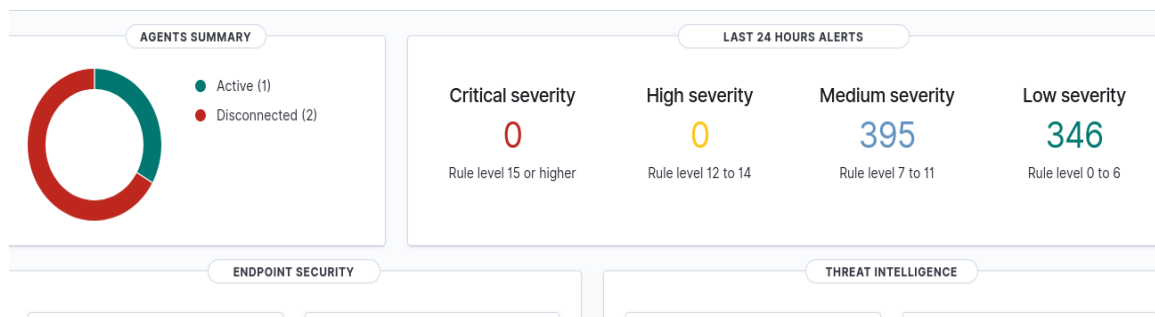
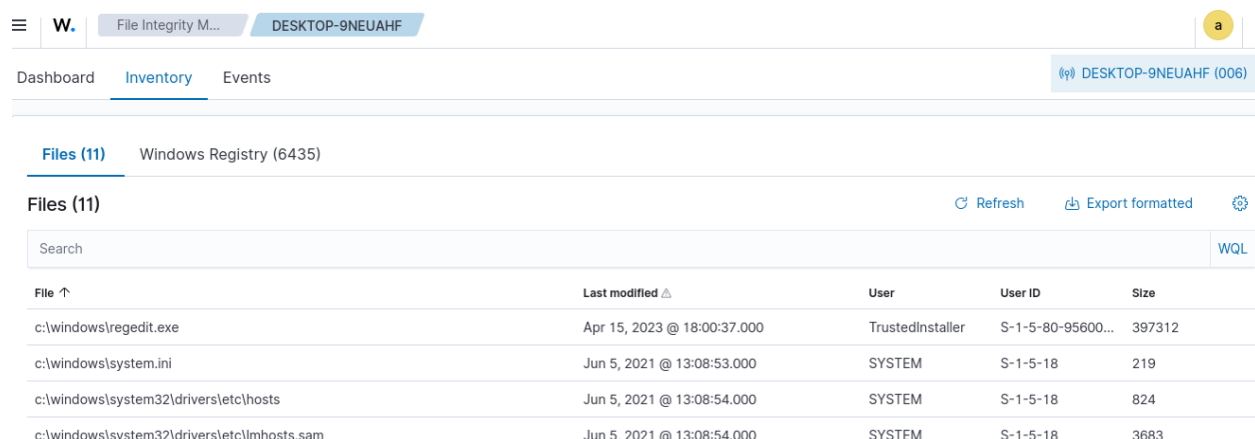


Figure 8: Active Agent Successfully reflected on the dashboard. **Note:** The other agents we created also reflected as disconnected.

4. Testing the File Integrity Monitoring

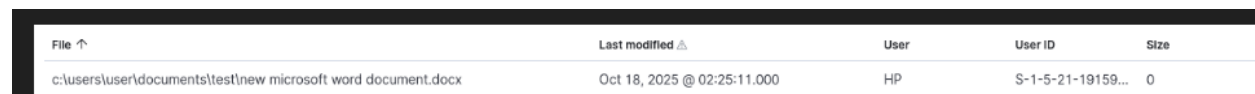
In this section, we proceeded to edit the agent configuration, here we added a word document to confirm how the agent will report. Once we restarted the agent and the dashboard, the document added successfully showed in the FIM. The **challenge here** was the Virtual Box continuously crashing and therefore impacting other tests, however the objectives of the lab were met and we were able to successfully demonstrate the reporting of any changes to the agent we installed. **Remediation** steps was restarting machine and all the environments, a **permanent solution** is to increase RAM size to 32GB to allow for seamless testing of all operations.



The screenshot shows the FIM dashboard for 'DESKTOP-9NEUAHF'. The 'Inventory' tab is active, displaying a list of files. The table includes columns for File, Last modified, User, User ID, and Size. The files listed are system files like regedit.exe, system.ini, hosts, and lmhosts.sam.

File ↑	Last modified ▲	User	User ID	Size
c:\windows\regedit.exe	Apr 15, 2023 @ 18:00:37.000	TrustedInstaller	S-1-5-80-95600...	397312
c:\windows\system.ini	Jun 5, 2021 @ 13:08:53.000	SYSTEM	S-1-5-18	219
c:\windows\system32\drivers\etc\hosts	Jun 5, 2021 @ 13:08:54.000	SYSTEM	S-1-5-18	824
c:\windows\system32\drivers\etc\lmhosts.sam	Jun 5, 2021 @ 13:08:54.000	SYSTEM	S-1-5-18	3683

Figure 9: The FIM before editing configurations



The screenshot shows the FIM dashboard after editing. A new file, 'c:\users\user\documents\test\new microsoft word document.docx', has been added to the list. The table shows its last modified date as Oct 18, 2025, and its size as 0 bytes.

File ↑	Last modified ▲	User	User ID	Size
c:\users\user\documents\test\new microsoft word document.docx	Oct 18, 2025 @ 02:25:11.000	HP	S-1-5-21-19159...	0

Figure 10: After editing, the details of modification appeared in the FIM.

Conclusion: This brings us to the successful end of the technical operation, we were able to install a monitoring tool, navigate the dashboard to review different ways of utilizing the tool from compliance to reporting, testing the file integrity monitoring and establishing how effective the tool as a detective control.

Part Two: GRC Workshop & Analysis Questions

In this section we connect the technical exercise to GRC Principles by answering key questions post Lab analysis. In this part, we give analysis basing on the leading questions provided as part of the assignment.

1. **Risk Identification & Analysis:** In the context of our scenario, the risk was "unauthorized modification of financial documents."

- ✓ What is the potential **business impact** (e.g., financial, reputational, operational) if this risk were realized?

Answer: we identified a potential risk that could negatively affect the organization's assets, operation and reputation, the risk is unauthorized modification of financial documents, if someone either internal

or external could access and change financial records without proper permission, it could have major impacts on business as specified but not limited to the below:

- a. **Financial Impact:** incase the file is modified, it could lead to **loss of revenue or organization's assets**, false financial data might change the true standing of the organization, we could also be exposed to **regulatory fines** due to non-compliance, it could also lead to inaccurate records which will impact audit and might even lead to **audit failures**.
- b. **Reputational Impact:** if partners, clients and other stakeholders learn of financial document tampering it could lead to **loss of trust**, news on financial manipulation could also potentially lead to **negative media coverage**, all this lead to reputational damage.
- c. **Operational Business Processes:** Business depends on financial records to **create budgets** which determine staffing and day to day operations, tampered financial records could potentially halt operations either by inflating or reducing the true picture on financials, and also once the issue is identified, it will have an impact on the operations because we will need to **allocate resources** and time to **correct the identified falsified documents**. Also **key staff** might face penalties and suspension or loss of work and this will **impact business continuity**.

- ✓ Based on the alerts you generated, how does this control help in **quantifying** the risk (e.g., frequency of events)?

Answer: Based on the alerts and behavior observed on the FIM, this control gives us measurable data which helps us in identifying the **frequency of the risk**, if we observe the rate of occurrence it can assist in identifying how often, **the trend** on whether the falsified documents are **occurring** at the same time and what **intervals** or at the time of occurrence what the organization was facing or the target, we could also understand **the source** i.e. who is the person or the object that is modifying the documents and the **systems they target**, and how severe the attempts are, whether **attempted** or **successful modification**.

2. **Control Evaluation & Treatment:** The implemented FIM is a **detective control**.

- ✓ What would be a complementary **preventive control** for this same risk?

Answer: a detective control works to informs you after something has occurred, in our case it informs us that a file has been modified, a **preventive control** would limit or stop the occurrence of the file being modified before it is modified, some of the ways we could prevent and upkeep file integrity is by using below sample preventive controls:

- a. **Role Based Access Control(RBAC)**, this ensures only the people whose role allows them to have access are given access.
- b. **Multifactor authentication(MFA)**: this is where authorized people are authenticated based on more than one authentication method, a combination of something you know (password), something you have (token) and something you are (biometrics) before access to the files, a combination of RBAC and MFA would give a layered defense.
- c. **Data Loss Prevention (DLP) solutions:** the DLP solution will stop modification and alert the administrator on attempts to modify a file.

- d. **Network Segmentation:** this separates networks according to zone and access to sensitive information or file are placed in a controlled section, only authorized and authenticated people can have access to this file based on role.
- e. **Limit Insider Threat:** employ several checks to limit insider threat either malicious or accidental by having for example a maker checker in place, in cases of modification, we will require an approver for every action done, also employ a monitoring solution for key systems.

This controls, will restrict who has access, employ layered defense that check for both external and internal threats, and reduce the chance of modification in the first place.

- ✓ Explain a situation where the alert from this detective control would trigger a **corrective control** (a response action).

Answer: A **corrective control** on the other hand, comes in after the file has been modified and identified, here the action works towards **fixing the issue or reducing the damage**. Once the detective control detects an issue it may trigger a corrective action to either investigate or fix the issue by either:

- a. **Rights Revocation:** A policy in place could lead to immediate isolation of user and denial of access if the action is outside the norm.
- b. **Restoring Original File:** this could also be a potential corrective response where we put a policy in place which is triggered by detective control, once triggered the immediate original file is restored from back up.
- c. **Incident Response Investigation:** the detective control can also trigger an incident response investigation where an instant report is generated stating the source of change, what was changes and at what time for analysis.

A combination of the three above or other corrective responses can be employed, this way an immediate response is triggered once an action outside of normal behavior is identified, ensuring the risk and business impact is reduced.

3. Risk Monitoring & Reporting:

- ✓ If you had to report on the **operational effectiveness** of this FIM control to a manager, what three key metrics would you pull from the Wazuh dashboard?

Answer: to report on the operational effectiveness I will **first analyze the pain points** that have been resolved by employing this control, so my assumption is we need to know the files modified, which ones are outside the norm and the response time to respond to a change, below is an explanation on how the metrics will assist:

- a. **Number of FIM Events** i.e. the number of files reported to have been modified: this metrics will help show, the number of files modified, created or deleted and how often this events occur, this will help us identify if we have an issue in our access right, alert us to a misconfiguration which allows modification based on the number of unexpected changes especially outside norm.

- b. **Number of Alerts or triggers** by unauthorized or suspicious changes especially outside norm, this will include the false positives and false negatives, giving us clarity on how effective the tool is and if we can rely on it as an effective detective tool.
 - c. **Time to detect and respond to FIM Alerts:** I will use this metrics to assist in analyzing the time between detection and response, either remediation or investigation, this will assist in quantifying whether the control is effective or a false sense of confidence in terms of risk exposure.
- ✓ How does centralizing this monitoring data, as opposed to checking logs on each individual computer, improve the **governance** and **auditability** of the risk management program?

Answer: we first look at **benefits of a centralized monitoring**, in an organization where we have several end-points and attack surfaces, a centralized monitoring means **better visibility** and **oversight**, having all systems and alerts in one place, this ensures patterns are quickly identified allowing **consistency** in organizational controls and policies. The consistency across systems also makes it easier for **audit reports** because we can centrally check who did what where and when, also because we do not have to go to individual systems incident detection and response is faster and more efficient.

Therefore, a centralized monitoring of data and files through the Wazuh dashboard improves governance by giving and **end to end visibility into all systems** monitored and all from one **single point**. We also have enhanced audit because the logs are consistent in collection and securely stored, incidents are easy to track and report. Overall checking individual system is time consuming, inconsistent and increases the risk of missed or altered events.

4. **Compliance Mapping:** Many regulations (like SOX, PCI DSS, HIPAA) require monitoring critical files for changes.

- ✓ How does a tool like Wazuh provide **evidence** for compliance audits?

Answer: once on boarded, Wazuh **continuously monitors** sensitive files and keeps a **record** of all events under the files, it tracks deletion, modification, creation etc. any form of tampering records inclusive of the user who did the changes and the time the change was done, it sends alerts for unauthorized modifications and retains the logs, this will serve as proof of compliance by showing all files are monitored as per standard, it also generates the reports in a centralized place and reduces the need for screenshots etc.

- ✓ Briefly describe how you would use the Wazuh dashboard to demonstrate to an auditor that a specific sensitive file has not been altered during a defined period (e.g., last quarter).

Answer: from the observation and navigation of the Wazuh dashboard, it is evident that files, once agents are installed, are monitored for any and all kind of **changes**, to demonstrate that a particular sensitive file has not been altered, I would utilize the **File Integrity Monitoring tool(FIM)** and filter logs for the last quarter or for the period required, search for events related and if no modification event are found (refer to below figure), I can confirm and show evidence that the file was not altered, I would then export this data as proof and verifiable evidence of file integrity.



Figure 11: A picture showing in FIM we can navigate to events.